

Clase 339 — Riesgos, guardrails, OPSEC y ética del hacking con IA

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: OWASP Top 10 for LLM · MITRE ATLAS · NIST AI RMF 🕒 Duración estimada: **100 min** · Nivel: **Avanzado**

🎯 Objetivo

Cerrar el círculo: los **riesgos de usar IA para hacer seguridad** y cómo mitigarlos. Tu propio agente es una superficie de ataque (prompt injection, fuga de datos), sus acciones deben ser auditables, y todo el uso está sujeto a un marco legal y ético donde la responsabilidad es humana. Esta clase te da los guardrails para operar con IA de forma profesional.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

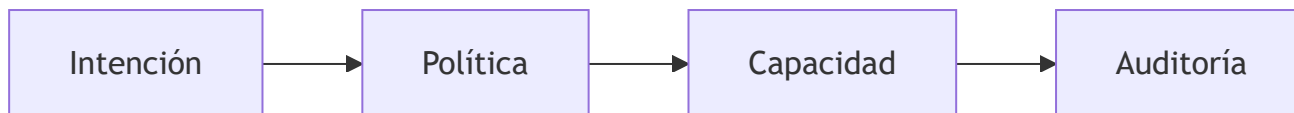
- 1. **Identificar** los riesgos de un agente de seguridad: prompt injection, exceso de agencia, fuga de datos.
- 2. **Diseñar** guardrails: mínimo privilegio, aprobación humana, aislamiento, límites de alcance.
- 3. **Auditar** las acciones del agente con trazabilidad completa.
- 4. **Aplicar** OPSEC al uso de IA (qué datos entran al modelo, dónde corre).
- 5. **Situar** el uso de IA en el marco legal y de responsabilidad profesional.

📖 Temas

#	Tema	Por qué importa
1	Prompt injection contra tu agente	Datos del objetivo pueden secuestrar sus instrucciones.
2	Exceso de agencia (excessive agency)	Un agente con demasiados permisos causa daño.
3	Fuga de datos	Enviar datos sensibles a un modelo externo.
4	Trazabilidad y auditoría	Cada acción del agente debe quedar registrada.
5	OPSEC del uso de IA	Modelo local vs nube, qué entra al contexto.
6	Marco legal y responsabilidad	La IA no diluye tu responsabilidad ni la autorización.

💡 Explicación en profundidad

Los guardrails son capas falibles: política, permisos, aislamiento, aprobación, límites, logging y respuesta. Una negativa del modelo no es frontera; una herramienta sin privilegio sí reduce capacidad.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

Una inyección logra que el modelo solicite un secreto, pero el broker no expone variables y registra el intento.

Glosario operativo

Término	Definición
Fail closed	Comportamiento que niega la operación cuando falta validación.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

Definiciones y características

Prompt injection : Instrucciones maliciosas ocultas en datos que el agente procesa (una web, un banner) que intentan cambiar su comportamiento. Riesgo LLM01 de OWASP.

Exceso de agencia (excessive agency) : Dar al agente más permisos/autonomía de la necesaria, de modo que un error o una inyección cause daño real. Riesgo LLM06.

Guardrail : Control que limita lo que el agente puede hacer (permisos mínimos, aprobación humana, listas de alcance, aislamiento de red).

OPSEC (seguridad operativa) : Disciplina de no exponer información sensible; aquí, controlar qué datos entran al modelo y dónde se ejecuta.

Trazabilidad : Registro auditable de cada acción del agente (comando, hora, resultado), imprescindible legal y operativamente.

Herramientas y preparación

Tu propio flujo de IA (de las clases anteriores). El ejercicio es de **diseño de controles**: políticas, permisos y registro. Revisa OWASP Top 10 for LLM como referencia.

Laboratorio guiado (diseño de guardrails)

1. **Modelo de amenazas del agente.** Enumera cómo podrían atacar tu agente (inyección desde un banner, fuga de credenciales del contexto, acción fuera de alcance).
2. **Matriz de permisos.** Clasifica sus herramientas en auto / aprobación / prohibido y justifica.
3. **Aislamiento.** Define la red y los datos a los que el agente **no** debe acceder.
4. **Registro.** Diseña el log de auditoría: qué campos guardas por cada acción.
5. **Política de datos.** Escribe qué datos jamás entran a un modelo externo y por qué.
6. **Checklist legal.** Redacta el mínimo legal antes de una sesión (autorización, alcance, ventana).

Ejercicios

1. Da un ejemplo concreto de prompt injection contra un agente de pentest y su mitigación.
2. ¿Qué es exceso de agencia y cómo lo limitas?
3. Diseña 3 campos imprescindibles de un log de auditoría del agente.
4. ¿Cuándo usarías un modelo local en vez de uno en la nube?
5. Explica por qué la IA no reduce tu responsabilidad legal.

Reto verificable

Redacta un **documento de guardrails** para operar un agente de seguridad: matriz de permisos, aislamiento, política de datos, registro de auditoría y checklist legal.

Criterio de aceptación: toda acción con impacto requiere aprobación humana; hay aislamiento de red; se define qué datos no salen al modelo; existe un registro auditable; se exige autorización por escrito antes de cualquier sesión.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El agente obedece instrucciones de una web/banner	Prompt injection. Trata los datos del objetivo como no confiables y no le des autonomía total.
Credenciales en el contexto del agente	Fuga potencial. Usa secretos gestionados, nunca en el prompt.
Sin registro de lo que hizo el agente	No hay auditoría ni defensa legal. Loguea cada acción.
"La IA lo hizo, no yo"	La responsabilidad es del operador humano. La IA no exime de nada.
Datos de cliente enviados a un modelo público	Posible incumplimiento legal. Modelo aprobado/local y anonimización.

Preguntas frecuentes

? ¿La IA me hace responsable de menos? No. Eres tan responsable como si hubieras ejecutado las acciones a mano. La autorización, el alcance y las consecuencias son tuyos.

? **¿Puede mi propio agente volverse en mi contra?** Sí, vía prompt injection: contenido malicioso en los datos que procesa puede intentar manipularlo. Por eso: mínimo privilegio, aprobación humana y aislamiento.

? **¿Modelo local o en la nube?** Para datos sensibles, local o aprobado por el cliente. Es una decisión de OPSEC y de cumplimiento, no solo de comodidad.

Referencias

- [OWASP Top 10 for LLM Applications](#) — LLM01, LLM06.
- [MITRE ATLAS · NIST AI RMF](#)
- Clase [025](#) (ética y legalidad) y Parte 15 (seguridad de la IA).

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 338](#) — Generación de informes y flujos de trabajo con IA

Siguiente clase

[Clase 340](#) — Capstone: pentest autorizado asistido por IA con MCP